

Case Study

This section evaluates whether the proposed pytm-Seq can identify multistage threats across the smart contract, industrial control system (ICS), automotive, satellite system, and cloud domains. To this end, we selected and analyzed 100 attack cases targeting these domains, together with authoritative cyber threat intelligence (CTI) sources that provide domain-specific threat information, such as Aerospace SPARTA and MITRE ATT&CK. Based on this analysis, we defined a total of 52 multi-step threat patterns. In this section, several of the aforementioned attack cases are selected to explain the process of defining multi-step threat patterns and to present the results of detecting these patterns in actual systems. The multi-step threat patterns and identification results for the remaining attack cases can be found in the pytm-Seq GitHub repository¹.

1 Case Study : Smart Contract Domain

In this subsection, we define multi-step threat patterns based on an analysis of the 2025 Yearn Finance attack, which resulted in an approximately USD 120 billion decrease in Ethereum’s market capitalization, and describe the process and results of identifying these patterns in a DFD using the pytm-Seq tool (CNBC, n.d.; Research, n.d.). Further details are provided in the following subsections.

1.1 Definition of multi-step threat patterns for the smart contract domain using an extended DFD metamodel

In this subsection, we identify the functional types and data transfers exploited in the attack based on the analysis of the 2025 Yearn Finance attack case, and describe the process and results of defining a multi-step threat pattern for this attack. According to the analysis report, the attacker first obtained unsecured funds by utilizing a Flash Loan service and then supplied these funds to a Liquidity Staking service(Research, n.d.). As a result, the supply of the cryptocurrency distributed as a staking reward changed abruptly, and the Oracle service consequently miscalculated the price of the cryptocurrency based on this abnormal supply change. The incorrectly calculated price was subsequently delivered to Yearn Finance, a derivative service (Synthesize), allowing the attacker to exchange the cryptocurrency corresponding to the derivative assets they held for other cryptocurrencies and thereby obtain illicit profits from the artificially increased price.

Function Types of Smart Contract

Function Type	Description
---------------	-------------

¹ All artifacts related to our work are publicly available at <https://github.com/sinse100/pytm-Seq>

Function Type	Description
Flash Loan	a smart contract that provides uncollateralized loans.
Peer Node	a blockchain node that executes smart contracts
Synthesize	a smart contract that issues derivative tokens
Liquidity Staking(LS)	a contract that issues liquidity tokens(LT)
Oracle	a contract that calculates price of token using LT supply from LS Contract

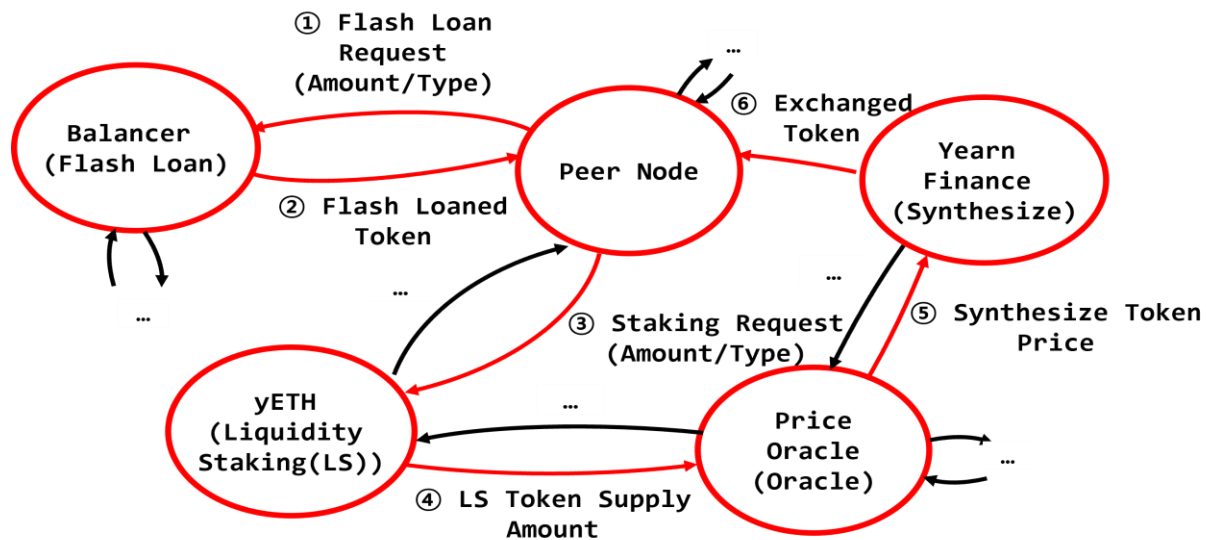
Based on these analysis results and information from the statistics platforms operated by organizations such as the Ethereum Foundation, we identified five functional types involved in the attack. Each functional type was then mapped to one of the publicly defined smart contract asset types, as shown in Table 1(DefiLLama, n.d.). Subsequently, six sequential data transfer patterns were converted into a JSON-formatted multi-step threat pattern that can be recognized by pytm-seq. Table 2 shows the multi-step threat pattern derived through the process described in this section.

Multi-Step Threat Pattern in Smart Contract

Source Function Type	Peer Node
Destination Function Type	Flash Loan
Source Function Type	Flash Loan
Destination Function Type	Peer Node
Source Function Type	Peer Node
Destination Function Type	Liquidity Staking
Source Function Type	Liquidity Staking
Destination Function Type	Oracle
Source Function Type	Oracle
Destination Function Type	Synthesize
Source Function Type	Synthesize
Destination Function Type	Peer Node

1.2 Analysis of Multi-Step Threat Patterns for the Smart Contract Domain within the DFD

This subsection presents the process and results of using pytm-Seq to identify the presence of the pattern defined in Section 5.A.1 within smart contracts. First, based on the modeled DFD, the node corresponding to the starting point of the multi-step threat pattern defined in Section 5.A was identified. In this process, the Aave smart contract, which provides Flash Loan-type functionality, was identified as the starting node of the multi-step threat pattern. Next, in order to identify the subgraph corresponding to the multi-step threat pattern within the DFD, the attack path was traced starting from Aave by following the steps described in Section 4.B. As a result, as shown in Figure. 10 below, an attack path was identified that begins at Aave, a smart contract that provides Flash Loan functionality, and leads to Yearn Finance, a smart contract that provides Synthesize functionality.



Identified Attack Path in Smart Contracts

1.3 Refining Threats by Smart contract-Level using LLM

This subsection describes the process and results of using an LLM to map vulnerabilities that could be exploited in each function, based on the function types and the sequence of interactions along the attack path identified in Section 5.A.2. For the smart contract domain, we utilized the mapping information between the security requirements defined in the OWASP Smart Contract Security Verification Standard (SCSVS) and the smart contract vulnerability classifications provided by SCWE and CWE. Specifically, the function-specific security requirements defined in SCSVS were used as detailed attribute information, that is, implementation information, for each smart contract represented in the DFD. The function type of each smart contract constituting the attack path and the detailed attribute information assigned to it in the DFD were then provided to the LLM. By analyzing this

information, the LLM identified vulnerabilities that could be exploited in each smart contract function and derived the corresponding CWE entries. Table 3 presents the results of applying this vulnerability-mapping procedure to the Synthesize and Price Oracle functions along the attack path identified in Section 5.A.2.

Vulnerabilities Associated with Smart Contract Type

=

Function Type	=	=	=	=
=	=	=	=	=
Oracle	SPID-521	Smart contract uses decentralized oracles to enhance data reliability	CWE-346	Origin Validation Error
=	=	=	=	=
Synthesize	SPID-524	Ensure mechanisms are in place to handle fluctuations in conversion rates.	CWE-367	Time-of-Check Time-of-Use (TOCTOU) Race Condition

1.4 Generation of a Report Based on the Analysis Results of Multi-Step Threat Patterns for the Smart Contract Domain

This subsection presents the process and results of generating an HTML-formatted report that summarizes the multi-step threat and threat analysis results based on the smart contract attack path identified in Section 5.A.2. First, pytm-Seq converts the attack path in the DFD of Section 5.A.2 into a JSON format. The JSON-formatted attack path is then rendered as an HTML report, as illustrated in Figure. 11. As shown in the report, the Attack Path section includes both the attack path identified from the DFD and information on the vulnerabilities that could be exploited in each smart contract along the path

Potential Threats

▼ Name: 2025 Yearn Finance attack

Attack Path : Peer Node → Balancer (Flash Loan) → Peer Node → yETH (Liquidity Staking) → Price Oracle (Oracle) → Yearn Finance (Synthesize) → Peer Node

Exploitable Vulnerability:
+ Price Oracle(Oracle) :

CWE	CVE
CWE-346	Origin Validation Error
...	

Generaed Threat Report for Smart Contract Domain

2 Case Study : ICS Domain

This subsection explains the process and results of defining a multi-step threat pattern based on the analysis of the 2022 Ukraine power grid attack incident and identifying the pattern in the DFD using the pytm-Seq tool. Further details are provided in the following subsections.

2.1 Definition of multi-step threat patterns for the ICS domain using an extended DFD metamodel

This subsection explains the process and results of identifying the functional types involved in the attack and the associated data transmissions based on the analysis of the 2022 Ukraine power grid attack incident, and defining a pattern based on these findings. To achieve this, we first reviewed publicly available incident analysis reports and technical documentation to analyse the system components involved in the attack and their functional roles. Through this analysis, we derived the functional flows that repeatedly appeared in the attack scenario and used them as the basis for defining a multi-step threat pattern. According to analysis reports and related materials on this attack incident, the attacker carried out the attack by abusing the generation and transmission procedure of SCIL commands (SCADA → Control Server → Data Historian → Application Server → RTU → IED), which are used to control remote switches. Although this procedure represents operational workflow used to deliver commands in a normal power control environment, the attacker disrupted the normal operation of the system by delivering malicious commands along this communication path. As a result, this command transmission process provided the attacker with a means to remotely control power equipment, thereby forming an attack path capable of causing disruption to the operation of the power grid.

Function Types In ICS Domain

Asset in MITRE ATT&CK for ICS

ICS components identified in the attack case

Gateway	a device that connects network segments, such as control networks and external networks.
Control Server	control server running the SCADA program
Data Historian	Log collection program that manages time-series data
Application Server	Application based on the SCIL library
RTU (Remote Terminal Unit)	RTU acting as a relay between the substation computing system and the power switches
IED (Intelligent Electronic Devices)	An IED is a smart electronic unit that monitors and controls power system equipment such as circuit breakers and relays.

Based on this procedure, we identified six system functions leveraged in the attack and

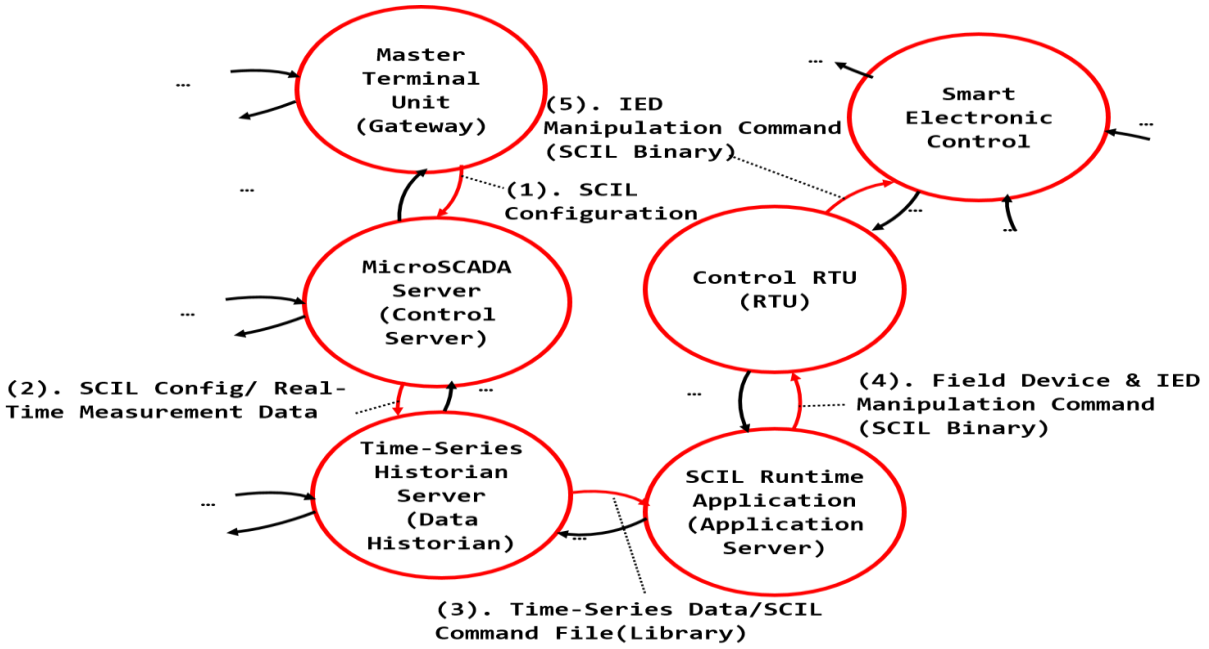
mapped each function to a corresponding asset in MITRE ATT&CK, resulting in a total of six mapped assets, as shown in Table 2. We then transformed the five sequential data transmission patterns into a JSON-formatted multi-step threat pattern recognizable by pytm-Seq. Figure 12 presents the resulting multi-step threat pattern in JSON format.

Multi-Step Threat Pattern in ICS

Source Function Type	Gateway
Destination Function Type	Control Server
Source Function Type	Control Server
Destination Function Type	Data Historian
Source Function Type	Data Historian
Destination Function Type	App Server
Source Function Type	App Server
Destination Function Type	RTU
Source Function Type	RTU
Destination Function Type	IED

2.2 Analysis of Multi-Step Threat Patterns for the ICS Domain within the DFD

In this subsection, we present the procedure and results of identifying the presence of the pattern defined in Section 5.B.1 within an actual ICS system using pytm-Seq. First, based on the modeled DFD, we identified the node corresponding to the starting point of the multi-step threat pattern defined in Section 5.B.1. Through this process, the Master Terminal Unit (MTU), which has the functional type Gateway, was confirmed as the initial node of the multi-step threat pattern. Next, to identify the subgraph corresponding to the multi-step threat pattern within the DFD, we traced the attack path starting from the Master Terminal Unit, following the procedure described in Section 4.B. As a result, as shown in Figure. 13, an attack path was identified that begins at the Master Terminal Unit—the initial node providing the Gateway function—and proceeds to the Smart Electronic Device, the terminal node providing the IED function.



Identified Attack Path in ICS

2.3 Refining Threats by ICS Component-Level using LLM

This section presents the process of mapping vulnerabilities that could be exploited in the functions constituting the attack paths identified in Section 5.B.2, along with the key results. To perform this mapping, we integrated information provided by MITRE ATT&CK and MITRE EMB3D. MITRE ATT&CK defines the types of assets targeted by attacks, whereas MITRE EMB3D specifies detailed attributes of embedded-system functions and the potential threats associated with those attributes. It also maps each threat to relevant vulnerability information represented by CWE and CVE entries.

In this study, we first mapped the asset types defined in MITRE ATT&CK to the functional types associated with each component in the attack paths. We then identified the detailed MITRE EMB3D attributes relevant to each function. The functional types, function-specific attributes were subsequently provided as input to the LLM. Based on the mappings between the detailed attributes and CWE/CVE entries defined in MITRE EMB3D, the LLM identified vulnerabilities that could potentially be exploited in each function. Table 6 presents the vulnerability information mapped to the RTU and Data Historian among the asset types listed in Table 6.

Vulnerabilities Associated with ICS Component

=

Function Type

=	=	=	=	=	=	=
Data Historian	PID-1241	Device includes DDR DRAM	CWE-1256	Improper Restriction of Software Interfaces to Hardware Interfaces	–	–
=	=	=	=	=	=	=
RTU	PID-23Q1	QNX uses microkernel IPC message-passing	CWE-362	Race Condition	CVE-2016-5195	Dirty COW: Linux kernel race condition in mm/gup.c ...

2.4 Generation of a Report Based on the Analysis Results of Multi-Step Threat Patterns for the ICS Domain

In this subsection, we present the process and results of generating an HTML-formatted threat analysis report based on the attack path identified in the ICS system in Section 5.B.2. First, pytm-Seq converts the attack path identified in the DFD in Section 5.B.2 into a JSON format. Subsequently, the JSON-formatted attack path is rendered as an HTML report, as shown in Figure. 14. As can be observed in the report, the attack path information identified from the DFD is included in the Attack Path section of the analysis report.

Potential Threats

▼ Name: 2022 Ukraine Electronic Power Attack

Attack Path : Master Terminal Unit (**Gateway**) → MicroSCADA Server (Control Server) → Time-Series Historian Server (**Data Historian**) → SCIL Runtime Application (Application Server) → Control RTU (RTU) → Smart Electronic Control (IED)

Exploitable Vulnerability:
+ RTU

CWE	CVE
CWE-362	Race Condition
CVE-2016-5195	Dirty COW:Linuxkernel race condition inmm/gup.c
...	

Generated Threat report for ICS Domain

3 Case Study : Cloud Computing Domain

This subsection describes the process and results of defining a multi-step threat pattern based on the analysis of the 2024 Salesforce data exfiltration and extortion campaign and identifying the pattern in a DFD using pytm-Seq. Further details are provided in the following subsections.

3.1 Definition of multi-step threat patterns for the Cloud Computing domain using an extended DFD metamodel

This section describes the process and results of identifying the functional types and data transfer flows involved in the 2024 Salesforce data theft and extortion campaign and defining a multi-step threat pattern based on the analysis results. To this end, publicly available incident analysis reports and technical documentation were reviewed to identify the system components used during the attack and analyze their functional roles. The analysis showed that the attacker induced users to grant OAuth access permissions to a malicious Salesforce Connected App and subsequently used the issued authentication tokens to access the Salesforce cloud environment. The attacker then repeatedly queried and collected CRM records stored on the database server using the Salesforce API and Data Loader and automatically exfiltrated the collected data through the cloud service’s external communication functionality. Thus, this attack can be characterized as an attack path that enabled large-scale data theft by exploiting legitimate OAuth authentication, cloud application integration, and API-based data processing procedures.

Based on the attack procedure described above, we identified five cloud system components involved in the attack and their respective functions. Each function was then mapped to a corresponding asset type defined in MITRE ATT&CK Enterprise, as shown in Table 5. Based on these mappings, the multi-step threat pattern was defined as Client / End-User Host → Authentication Server → Cloud Environment → Database Server → Cloud Environment. Table 6 illustrates the defined multi-step threat pattern.

Function Types of Cloud Computing Domain

Asset in MITRE ATT&CK for Enterprise	Cloud Computing components identified in the attack case
Client / End-User Host	A user endpoint that receives external input and supports routine business operations.
Authentication Server	A server that verifies user accounts and access privileges. It may be targeted through stolen credentials, authentication process modification, account discovery, or account manipulation.
Cloud Environment	An environment that hosts cloud-based applications and services
Database Server	A server that stores and provides access to organizational and customer data.

Multi-Step Threat Pattern in Cloud Computing Domain

Source Function Type	Client / End-User Host
Destination Function Type	Authentication Server

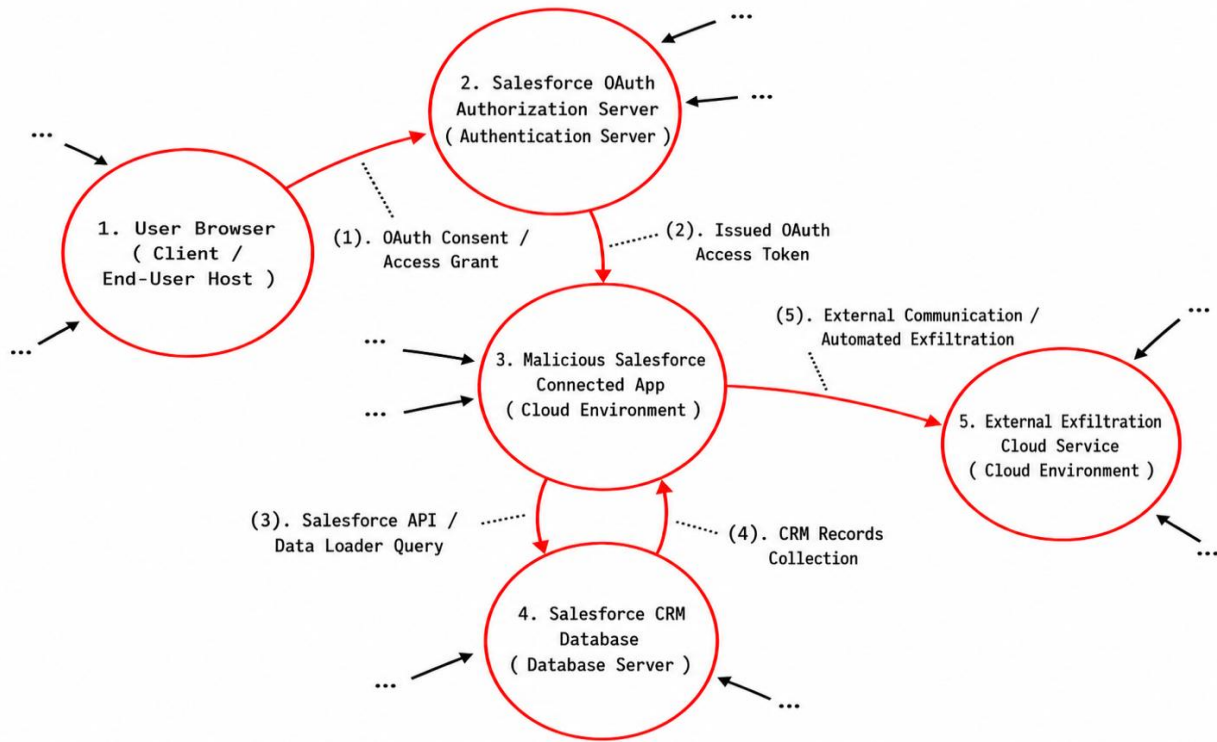
Source Function Type	Authentication Server
Destination Function Type	Cloud Environment

Source Function Type	Cloud Environment
Destination Function Type	Database Server

Source Function Type	Database Server
Destination Function Type	Cloud Environment

3.2 Analysis of Multi-Step Threat Patterns for the Cloud Computing Domain within the DFD

This subsection presents the process and results of using pytm-Seq to identify whether the multi-step threat pattern defined in the preceding subsection exists within an actual cloud system. First, based on the modeled DFD, the node corresponding to the starting point of the defined multi-step threat pattern was identified. In this process, the user endpoint with the Client / End-User Host function type was identified as the initial node of the pattern. Next, to identify the subgraph corresponding to the multi-step threat pattern within the DFD, the attack path was traced from the user endpoint according to the procedure described in subsection 5.C.2. As a result, as shown in Fig. 14, an attack path was identified that begins at the user endpoint, which serves the Client / End-User Host function, sequentially traverses the Authentication Server, Salesforce Cloud Environment, and CRM Database Server, and ultimately reaches the Salesforce API, the terminal node that serves the Cloud Environment function.



Identified Attack Path in Cloud Computing Domain

3.3 Refining Threats by Cloud Component-Level using LLM

This subsection presents the process of mapping vulnerabilities that could be exploited in each function constituting the Salesforce data exfiltration attack path identified in the preceding subsection, along with the key results. As in the procedure described in Section 5.B.3, the vulnerability mapping process utilized asset-type information from MITRE ATT&CK, information from MITRE EMB3D, and publicly available CWE and CVE data. Specifically, the Client / End-User Host, Authentication Server, Cloud Environment, and Database Server functions constituting the attack path were mapped to the asset types defined in MITRE ATT&CK Enterprise, after which detailed attribute information, potential threats, and vulnerabilities associated with each function were identified. The asset type and detailed function-level attribute information for each component were then provided to the LLM to derive the CWEs and CVEs that could be exploited during OAuth authorization acquisition, cloud application access, CRM data retrieval, and external data exfiltration. Table 6 presents the major vulnerabilities mapped to the Authentication Server and Database Server functions along the attack path identified in Section 5.C.2.

Vulnerabilities Associated with Cloud Component

=

Function Type

=	=	=	=	=	=	=
Authent-ication Server	PID-4113	Includes cryptographic functions for sensitive data	CWE-295	Improper Certificate Validation	CVE-2014-0160	Heartbleed: OpenSSL 1.0.1a–1.0.1f TLS heartbeat extension ...
=	=	=	=	=	=	=
Database Server	PID-4112	Lacks protocol support for message encryption	CWE-319	Cleartext Transmission of Sensitive Information	CVE-2014-3566	POODLE: TLS 1.0 downgrade to SSLv3 padding oracle ...

3.4 Generation of a Report Based on the Analysis Results of Multi-Step Threat Patterns for the Cloud Computing Domain

This subsection presents the process and results of generating an HTML report containing the multi-step threat and threat analysis results based on the attack scenario information identified in Sections 5.C.2 and 5.C.3. First, pytm-Seq converts the attack path identified in the DFD in Section 5.C.2 into JSON format. It then generates the HTML report shown in Fig. 14 using the JSON-formatted attack path. As shown in the report, the attack path information identified from the DFD and the associated vulnerability information are included in the Attack Path and Exploitable Vulnerability sections of the analysis report.

Potential Threats		
▼ Name: Salesforce attack Incident 2024		
Attack Path : User Browser(Client/End-User Host) → Salesforce OAuth Authorization Server(Authentication Server) → Malicious Salesforce Connected App(Cloud Environment) → Salesforce CRM Database(Database Server) → Malicious Salesforce Connected App(Cloud Environment) → External Exfiltration Cloud Service (Cloud Environment)		
Exploitable Vulnerability: + AuthenticationServer :		
CWE	CVE	
CWE-362	Improper Certificate Validation	Heartbleed:OpenSSL1.0.1a1.0.1f TLS heartbeat extension ...

Generated Threat Report for Cloud Domain

4 Case Study : Automotive Domain

This section describes the process and results of defining a multi-step threat pattern based on the analysis of the 2024 Tesla Model S in-vehicle network intrusion case and identifying the pattern in a DFD using pytm-Seq. Further details are provided in the following subsections.

4.1 Definition of multi-step threat patterns for the Automotive domain using an extended DFD metamodel

This subsection describes the process and results of identifying the function types and data flows involved in the attack based on an analysis of the 2024 Tesla Model S in-vehicle network intrusion case and defining a multi-step threat pattern accordingly. To this end, publicly available attack analyses and technical documents were reviewed to examine the vehicle system components involved in the attack and the functional role of each component. The analysis showed that the attacker exploited a vulnerability in the IVI system’s web browser to gain access to the vehicle’s infotainment environment and obtain user-level code execution privileges. The attacker then used the compromised IVI system to transmit manipulated messages over the vehicle’s internal infoCAN network and crafted bypass messages designed to evade the gateway’s filtering mechanisms. These messages passed through the gateway and reached the Body Control Module (BCM) on the bdCAN network, enabling unauthorized control of body functions such as opening the vehicle doors or starting the vehicle. Thus, this attack can be regarded as an attack path that sequentially exploits the normal message transmission procedures of the IVI browser, in-vehicle network, and gateway to reach vehicle control functions.

Function Types of Automotive Domain

Asset in Automotive Domain	Automotive components identified in the attack case
Web Application	A browser-based application that provides the initial entry point.
IVI System	An in-vehicle infotainment that executes the compromised codes to the vehicle network.
Gateway	A network component that routes messages between different in-vehicle networks and enforces filtering
Body Control Module (BCM)	An ECU that controls vehicle body functions, such as door locking and vehicle startup, based on received network messages.

Based on this attack procedure, we identified the components exploited and the functions performed by each component. We then mapped each function to the corresponding vehicle asset type, as shown in Table 10, by referring to the vehicle asset types defined in

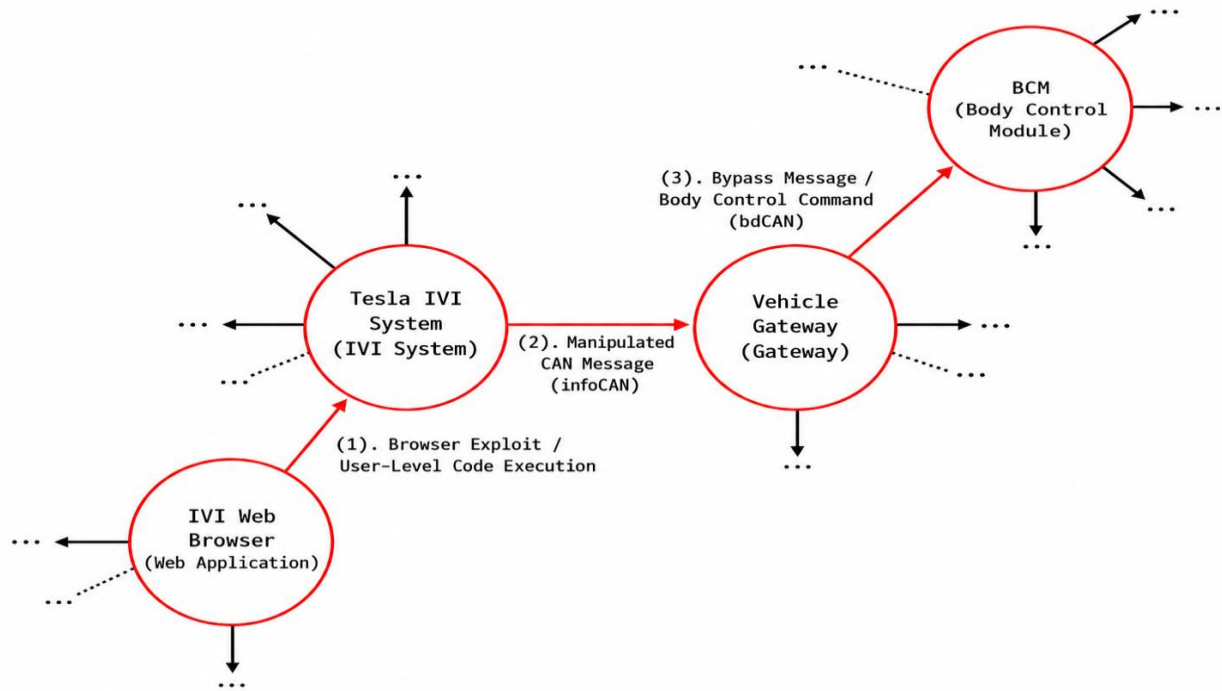
CarVal, a Datalog-based threat identification language designed for automotive systems, as well as vehicle threat information provided by automotive-specific CTI sources, including VATT&EK, ATHENA, and AUTO-ISAC. Based on this mapping, the multi-step threat pattern was defined as Web Application → IVI System → Gateway → Body Control Module (BCM). Table 11 presents the multi-step threat pattern defined above.

Multi-Step Threat Pattern in Cloud Computing Domain

Source Function Type	Web Application
Destination Function Type	IVI System
Source Function Type	IVI System
Destination Function Type	Gateway
Source Function Type	Gateway
Destination Function Type	Body Control Module

4.2 Analysis of Multi-Step Threat Patterns for the Automotive Domain within the DFD

This subsection presents the process and results of using pytm-Seq to determine whether the multi-step threat pattern defined in Section 5.D.1 exists within the system. First, based on the DFD, the node corresponding to the starting point of the multi-step threat pattern defined in Section 5.D.1 was identified. In this process, the IVI Web Browser, which has the Web Application function type, was identified as the starting node of the pattern. Next, to identify the subgraph corresponding to the multi-step threat pattern within the DFD, the attack path was traced from the IVI Web Browser according to the procedure described in Section 4.B. As a result, as shown in Fig. 16, an attack path was identified that begins at the IVI Web Browser, the initial node providing the Web Application function, sequentially traverses the IVI System and Gateway, and ultimately reaches the BCM, the terminal node providing the Body Control Module function.



Identified Attack path in Automotive

4.3 Refining Threats by Automotive Component-Level using LLM

This subsection presents the process of mapping vulnerabilities that could be exploited in each function constituting the attack path identified in the preceding subsection, along with the results. The vulnerability-mapping procedure was performed in a manner similar to the method described in Section 5.C.3 and utilized automotive asset information defined in CarVal, function-specific attribute and threat information from MITRE EMB3D, and CWE and CVE data. Specifically, the Web Application, IVI System, Gateway, and Body Control Module functions constituting the attack path were mapped to the corresponding automotive asset types, after which the detailed attributes and potential threats associated with each function were identified. The asset type and detailed attribute information for each component were then provided to the LLM to derive the CWEs and CVEs that could be exploited during IVI web browser compromise, manipulated CAN message transmission, gateway filtering bypass, and BCM control. Table 12 presents the vulnerabilities mapped to the IVI System and Gateway functions along the attack path identified in the preceding subsection.

Vulnerabilities Associated with Automotive Component

=

Function Type

=	=	=	=	=	=	=
IVI System	PID-IVI1	IVI uses embedded browser engine exposed to remote web content	CWE-284	Improper Access Control	CVE-2016-4657	WebKit in Apple iOS before 9.3.5 allows remote ...
=	=	=	=	=	=	=
Gateway	PID-42	Procedure to forward or route network messages	CWE-693	Protection Mechanism Failure	CVE-2023-28907	There is no memory isolation between ...

4.4 Generation of a Report Based on the Analysis Results of Multi-Step Threat Patterns for the Automotive Domain

This subsection presents the process and results of generating the report based on the attack scenario information 5.D.2 and 5.D.3. First, pytm-Seq converts the information identified in 5.D.2 and 5.D.3 into JSON format. It then uses the the information to generate the report shown in Fig. 17. As shown in the report, the attack path information identified from the DFD and the associated vulnerability information are included in the Attack Path and Exploitable Vulnerability sections of the report.

Potential Threats

▼ Name: 2024 Tesla Model S In-Vehicle Network Intrusion Case

Attack Path : IVI Web Browser (**Web Application**) → Tesla IVI System (**IVI System**) → Vehicle Gateway (**Gateway**) → BCM (**Body Control Module**)

Exploitable Vulnerability:
+ IVI System

CWE		CVE	
CWE-284	Improper Access Control	CVE-2016-4657	WebKit inApple iOS before 9.3.5 allows remote ...
...			

Generated Threat Report for Automotive

5 Case Study : Space Domain

This subsection describes the process and results of defining a multi-step threat pattern based on an analysis of the 2022 cyberattack against the management network and user terminals of the Viasat KA-SAT satellite communication system and identifying the pattern in a DFD using pytm-Seq. Further details are provided in the following subsections.

5.1 Definition of multi-step threat patterns for the Space domain using an extended DFD metamodel

This subsection defines a multi-step threat pattern based on the 2022 Viasat KA-SAT cyberattack. We reviewed publicly available incident reports and technical materials to identify the space-system components involved in the attack. The analysis showed that the attacker accessed the KA-SAT ground management environment through a misconfigured VPN appliance and used ground-segment management functions to send destructive commands to multiple user terminals. These commands were transmitted through the ground communication function, relayed by the satellite, and received by user-segment modems. The modems then executed destructive code, which overwrote memory and prevented the bootloader from loading a valid system image. Therefore, this attack can be interpreted as a multi-step attack path that sequentially exploited remote access, ground command distribution, satellite communication relay, user-terminal communication, modem execution, and boot procedures. Table 14 presents the defined multi-step threat pattern.

Multi-Step Threat Pattern in Space Domain

Source Function Type	Ground Station Access Terminal
Destination Function Type	Ground Station Commander
Source Function Type	Ground Station Commander
Destination Function Type	Ground Station Transceiver
Source Function Type	Ground Station Transceiver
Destination Function Type	Satellite Communication Module
Source Function Type	Satellite Communication Module
Destination Function Type	User Device
Source Function Type	User Device
Destination Function Type	OS

Source Function Type OS
Destination Function Type Boot Loader

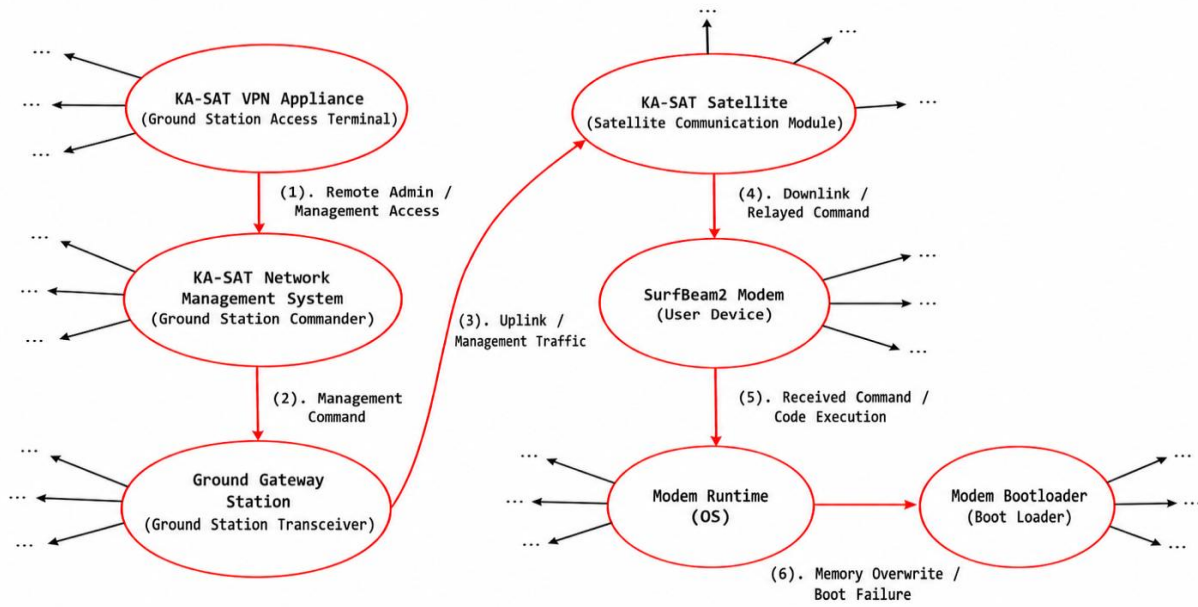
Based on the attack procedure described above, we identified seven space-system functions involved in the attack and mapped each function to the corresponding space-domain asset type. The results are shown in Table 13. This mapping was performed by referring to space-system component classifications used in prior studies on space systems and NASA technical documents, as well as general digital artifact information provided by the D3FEND Artifact Ontology.

Function Types of Space Domain

Asset in Space Domain	Space-system components identified in the attack case
Ground Station Access Terminal	A VPN appliance that provided remote access to the KA-SAT ground station.
Ground Station Commander	A ground-segment management function used to distribute commands to user terminals.
Ground Station Transceiver	A communication function that transmitted management traffic toward the satellite.
Satellite Communication Module	A communication function that relayed traffic between the ground segment and the user.
User Device	A modem that received management traffic from the satellite network.
OS	A modem execution environment.
Boot Loader	A modem boot function.

5.2 Analysis of Multi-Step Threat Patterns for the Space Domain within the DFD

This subsection presents the process and results of using pytm-Seq to determine whether the multi-step threat pattern defined in Subsection 5.E.1 exists within the modeled KA-SAT system. Based on the DFD, the Ground Station Access Terminal, which provides remote access to the KA-SAT ground management environment, was identified as the initial node of the pattern. The attack path was then traced from this node according to the procedure described in Section 4.B. As shown in Fig. 18, the identified path sequentially traverses the Ground Station Commander, Ground Station Transceiver, Satellite Communication Module, User Device, and OS, ultimately reaching the Boot Loader.



Identified Attack path in Space System

5.3 Refining Threats by Space System Component-Level using LLM

This subsection presents the process of mapping CWE entries that could be exploited in each function constituting the KA-SAT attack path identified in Section 5.E.2, along with the key results. To perform this mapping, we used the function types defined in Section 5.E.1, detailed implementation attributes assigned during DFD modeling, and TTP–CWE mapping information. For the space domain, detailed implementation attributes were derived by analyzing the applicability conditions of space-domain TTPs. Specifically, we first identified the implementation-level artifacts to which each space-domain TTP could apply by using the logical chain of SPARTA TTP → MITRE ATT&CK TTP → D3FEND artifact. We then used the structural relationships in the D3FEND Artifact Ontology to translate these artifacts into implementation attributes of DFD functions. For example, when a D3FEND artifact is defined as a subtype of a more general artifact, the corresponding property can be assigned to the relevant function in the DFD. In this way, conditions such as whether a function provides remote access, uses an authentication mechanism, implements a communication protocol, receives command traffic, accesses nonvolatile memory, or loads a boot image were represented as detailed implementation attributes. The function type and detailed implementation attribute information for each function were then provided to the LLM, together with the TTP–CWE mapping information. By analyzing this information, the LLM identified CWE entries that could be exploited in each space-system function. Table 15 presents the results of applying this vulnerability-mapping procedure to the Ground Station Access Terminal, Ground Station Commander, Ground Station

Transceiver, Satellite Communication Module, User Device, OS, and Boot Loader functions along the attack path identified in Section 5.E.2.

Vulnerabilities Associated with Space System Component

=

Function Type	=	=	=	=	=	=
=	=	=	=	=	=	=
Ground Station Transceiver	SPID-COM 1	Uses a communication protocol to transmit management traffic across segment boundaries	CWE -345	Insufficient Verification of Data Authenticity	CVE-2023-27979	Insufficient verification in IGSS Data Server allows crafted TCP ...
=	=	=	=	=	=	=
Satellite Communication Module	SPID-REL1	Relays uplink and downlink command traffic across segment boundaries	CWE -346	Origin Validation Error	CVE-2025-1102	Origin validation error in Q-Free MaxTime CORS configuration ..

5.4 Generation of a Report Based on the Analysis Results of Multi-Step Threat Patterns for the Space Domain

This subsection presents the generation of an HTML threat analysis report using the outputs from Sections 5.E.2 and 5.E.3. pytm-Seq converts the identified attack path and mapped vulnerabilities into JSON and renders them as the HTML report shown in Fig. 19. The report includes the KA-SAT attack path in the Attack Path section and the CWE/CVE information mapped to the relevant space-system elements in the Exploitable Vulnerability section.

Potential Threats

▼ Name: 2022 Viasat KA-SAT cyberattack

Attack Path : KA-SAT VPN Appliance (**Ground St. Access Terminal**) → KA-SAT Network Management System (**Ground St. Commander**) → Ground Gateway Station (**Ground St. Transceiver**) → KA-SAT (**Satellite Communication Module**) → SurfBeam2 Modem (User Device) → Modem Runtime(**OS**) → Modem Bootloader(**Boot Loader**)

Exploitable Vulnerability:

+ Ground Station Transceiver

CWE		CVE	
CWE-345	Insufficient Verification of Data Authenticity	CVE-2016-4657	Insufficient verification in IGSS Data Server
...			

Generated Threat Report for Automotive